FACULTAD DE DEFENSA NACIONAL — FADENA

Licenciatura en Ciberdefensa | Tecnología Operativa 2026

Documento de Cátedra N°17 — Doctrina de Seguridad OT: Análisis de Riesgos y la Inversión de la Tríada CIA a AIC

Sección 5 — Actividades de Verificación y Análisis

Actividad 1 — Tríada AIC aplicada al sistema de generadores de Base Logística Sur

a) Falla de cada propiedad AIC (componente A, PLCs S7-300)

Propiedad	Qué significaría una falla concreta	Consecuencia física esperada
Disponibilidad	El PLC pierde la capacidad de operar (ransomware, error de configuración, o apagado preventivo) y el generador no puede arrancar o sostener carga cuando falla la red principal.	Pérdida total de energía en la sala de comunicaciones y el NOC — categoría Operacional/Misión (Sección 2.3): pérdida de energía crítica en sala de Comando y Control durante operación militar activa.
Integridad	Un comando técnicamente válido (Modbus/DNP3 correctamente formado, credenciales legítimas) se ejecuta en un momento o estado físico inadecuado — el caso Aurora exacto.	Daño mecánico/eléctrico irreversible al generador, análogo a la destrucción en tres segundos del INL.
Confidencialidad	Un adversario obtiene visibilidad de la telemetría (estado de carga, horarios, niveles de combustible) sin alterar ni interrumpir nada.	Sin consecuencia física inmediata; habilita reconocimiento para un ataque posterior sobre Disponibilidad o Integridad.

b) ¿Aplica el escenario Aurora? Evento equivalente de Integridad

Aurora requiere específicamente una reconexión fuera de sincronía con una red eléctrica externa. Si los tres generadores de Base Logística Sur no se sincronizan con la red pública, el mecanismo literal no es directamente aplicable.

Existe sin embargo un evento equivalente: la sincronización entre los propios generadores entre sí. Si los tres grupos electrógenos (componente A) operan en paralelo compartiendo carga sobre el mismo bus, existe un breaker de acoplamiento entre unidades. Un comando técnicamente válido que cierre ese breaker mientras los generadores están fuera de fase entre sí reproduce la física exacta del experimento Aurora — mismo esfuerzo mecánico y eléctrico, pero entre unidades propias en lugar de contra la red pública. El comando sigue siendo auténtico en términos de protocolo; el problema sigue siendo el momento y el estado físico, no la sintaxis.

c) Por qué priorizar Confidencialidad sobre Disponibilidad sería incorrecto

La Sección 1.1 establece que en OT el orden AIC se invierte porque el activo protegido es un proceso físico en ejecución continua. El propio documento advierte: cifrar exhaustivamente el tráfico Modbus a costa de latencia que retrase la respuesta de un lazo de control crítico puede ser una decisión de seguridad incorrecta en OT.

Aplicado a Base Logística Sur: si se implementara cifrado pesado sobre la telemetría de los generadores que introdujera latencia en el lazo de control, y ese lazo necesita reaccionar en

milisegundos ante una falla de la red principal, la consecuencia sería la que advierte la Sección 1.1: un control que prioriza confidencialidad sobre disponibilidad puede causar más daño que el incidente que pretendía prevenir. El costo sería la diferencia entre energía continua o un corte en la sala de comunicaciones durante una operación activa — consecuencia Operacional/Misión catastrófica según la Sección 2.3 cuando no hay redundancia disponible.

Actividad 2 — Clasificación de riesgo: URGENT/11 en PLCs de combustible

a) Estimación de probabilidad

Probabilidad: Posible.

Los PLCs afectados corresponden a la zona de control físico crítico (SL3: adversario con recursos moderados y habilidades específicas en sistemas de control, según el AP N°15, Sección 4.2). URGENT/11 es una vulnerabilidad estructural y no remediable por parcheo (Sección 2.1, citando Doc. N°16, Sección 4) — no hay ventana de parcheo que cierre la exposición con el tiempo. Al ser una vulnerabilidad pública y documentada, el umbral de capacidad técnica requerido baja considerablemente una vez que el adversario alcanza acceso de red al segmento de los PLCs, sin requerir recursos de actor estatal (SL4). El factor limitante es alcanzar el segmento de red, no la dificultad de explotación en sí; por eso la probabilidad es Posible y no Improbable ni Probable.

b) Clasificación de consecuencia

Categoría	Clasificación	Justificación
Seguridad humana	Catastrófica	La Sección 2.3 establece que cualquier escenario con probabilidad no nula de fatalidad se considera automáticamente catastrófico. Una válvula de combustible manipulada (apertura/cierre fuera de secuencia, sobrepresión) tiene probabilidad no nula de incendio o explosión con riesgo de vida.
Ambiental	Mayor a Catastrófica (según volumen)	Manipulación de válvulas de carga/descarga puede provocar derrame; si requiere remediación de más de un año o contamina cuerpos de agua, la Sección 2.3 lo clasifica como catastrófico.
Operacional/Misión	Mayor	La pérdida de control de las válvulas compromete la capacidad de abastecimiento, aunque no necesariamente de forma irreversible si existen rutas alternativas de suministro.

c) Ubicación en la matriz y acción ALARP

Posible × Catastrófica (Seguridad humana, la categoría más severa) = EXTREMO, según la matriz de la Sección 2.2.

Acción obligatoria (Tabla ALARP, Sección 4): acción inmediata — aislamiento, segmentación de emergencia o suspensión de la función afectada hasta reducir el riesgo; no es ALARP-aceptable mantener la operación sin mitigación inmediata.

Responsable de la aceptación formal: la autoridad de mayor nivel de la cadena de mando aplicable (análogo a la Authority to Operate del marco RMF) — el nivel EXTREMO escala la decisión por encima del responsable técnico y del jefe de sección.

Frecuencia de revisión: continua hasta confirmar la reducción del nivel de riesgo, con reporte inmediato a la cadena de mando.

Actividad 3 — Cuatro fases de CIE en el sistema de combustible militar

a) Fase 1 — Priorización de consecuencias

Evento de consecuencia más catastrófica: apertura o sobrellenado no controlado de un tanque de combustible que provoque derrame masivo con riesgo simultáneo de incendio/explosión.

Categorías de la Sección 2.3 activadas: Seguridad humana (riesgo de fatalidad por incendio/explosión, automáticamente catastrófica) y Ambiental (derrame con contaminación), con un componente secundario en Operacional/Misión si el tanque comprometido es la única fuente de abastecimiento disponible.

b) Fase 2 — Análisis de sistema de sistemas (dos rutas)

- Ruta 1 — cibernética vía gateway IIoT: el gateway de monitoreo remoto del nivel de combustible (análogo al componente F de Base Logística Sur) tiene, además del canal de solo lectura previsto, capacidad de configuración remota no suficientemente restringida. Un adversario compromete la plataforma cloud del proveedor de mantenimiento predictivo y, si el gateway no está estrictamente limitado a telemetría unidireccional, pivotea hacia comandos de control sobre las válvulas.
- Ruta 2 — vector de convergencia del Doc. N°15: un servidor dual-homed (mismo patrón que el componente E, PI Historian) conecta la red SCADA del sistema de combustible con la red corporativa IT. Un ransomware que compromete IT pivotea a través de ese puente sin explotar ninguna vulnerabilidad del gateway IIoT, reutilizando credenciales legítimas para enviar comandos de apertura/cierre de válvula — misma lógica que el caso Maroochy: el comando es auténtico, el origen es ilegítimo, y ningún control perimetral de Security lo distingue.

c) Fases 3 y 4 — Focalización y mitigación de ingeniería

Control de ingeniería propuesto: un interlock mecánico de sobrellenado (high-level float switch acoplado a una válvula de cierre de emergencia) instalado físicamente en cada tanque, que corta el flujo de carga al alcanzar el nivel máximo seguro de forma completamente independiente del PLC, del SCADA y del gateway IIoT — análogo directo al relé de sincronía de fase descrito para Aurora.

Por qué resuelve ambas rutas simultáneamente: tanto la Ruta 1 (gateway comprometido) como la Ruta 2 (pivote vía dual-homed) terminan en el mismo punto de actuación físico — el comando de apertura de válvula. El interlock no pregunta quién envió el comando, sino que actúa sobre el estado físico real del tanque, sin importar qué ruta cibernética produjo la orden. Es el cambio de pregunta que describe la Sección 3: no “cómo evito que el adversario envíe el comando” sino “cómo diseño el sistema para que ese comando, por cualquier ruta, no pueda producir el sobrellenado”.

Actividad 4 — Colonial Pipeline reanalizado bajo ALARP

a) Por qué la incertidumbre impidió clasificar el riesgo

La matriz de la Sección 2.2 requiere conocer probabilidad y consecuencia para ubicar un evento en una celda. Colonial Pipeline no podía estimar la probabilidad real de que el ransomware alcanzara el OT porque no tenía evidencia verificable de que la segmentación IT/OT existiera y funcionara — la misma situación que el Historian dual-homed y la ausencia de DMZ 3.5 en Base Logística Sur. Sin saber si existía una ruta de propagación viable, no podían distinguir entre un escenario Improbable (segmentación verificada) y uno Probable (sin segmentación real).

Información faltante necesaria: logs de firewall que confirmaran ausencia de tráfico anómalo entre IT y OT (el log de FW-2 de la arquitectura revisada del AP N°15), un inventario verificado de dispositivos dual-homed, y datos de monitoreo con presencia real en el lado OT — las tres fuentes de información diseñadas en la Pregunta 5 de Fase 3 del AP N°15.

b) Por qué tratar lo no clasificable como EXTREMO es consistente con ALARP

ALARP exige documentar explícitamente por qué un riesgo residual se considera aceptable, lo cual requiere conocer el nivel de riesgo con confianza como condición previa. Sin esa clasificación, no hay base documental para justificar una aceptación parcial; la única postura defendible es tratar el riesgo como el peor caso posible hasta tener evidencia que permita reclasificarlo. La Sección 4 lo afirma textualmente: la única acción consistente con un nivel de riesgo no clasificable es tratarlo como EXTREMO por precaución — no es sobrerreacción, es la aplicación literal del principio precautorio que ALARP exige cuando la clasificación con confianza no es posible.

c) Arquitectura de monitoreo mínima

- DMZ 3.5 con dos firewalls de logging activo (FW-1, FW-2): no solo bloquean tráfico, generan el registro que permite, durante un incidente, demostrar ausencia de conexiones anómalas IT→OT en tiempo real (función Detect del NIST CSF).
- Historian Mirror con verificación de consistencia continua: permite inferir el estado de salud del OT sin necesidad de conectarse directamente a esa red.
- Aplicación previa de la Fase 1 de CIE: tener ya identificado y documentado el evento catastrófico inaceptable del pipeline (ej. apertura no controlada de una válvula de bombeo) permite, durante el incidente, evaluar específicamente si las rutas hacia ese evento están cerradas, en lugar de evaluar el sistema completo bajo presión de tiempo.

Con esta arquitectura, Colonial Pipeline habría podido consultar los tres puntos de evidencia durante el incidente, clasificar el riesgo real como probablemente BAJO o MEDIO (ransomware contenido en IT, sin tráfico anómalo hacia OT, Historian Mirror sincronizando con normalidad), y aplicar la acción ALARP proporcional a ese nivel — mitigación dentro del ciclo normal en lugar de aislamiento total del oleoducto.